QAYRAWAN INFORMATION SYSTEMS

Business Continuity Plan

ECC Compliance Program · Operate phase

Document ID	QIS-BCP-001
Version	0.2 (Draft)
Date	9 November 2026
Classification	Internal
Prepared by	Naif Alsalem, GRC Lead

Language. This document is issued in Arabic and English. In case of conflict, the Arabic text prevails.

Fictional case study. Qayrawan Information Systems (QIS), its people and its clients are invented for a professional portfolio. Any resemblance to a real organization is unintended. The regulators and frameworks named are real.

Document control

Role	Job title	Name	Status
Owner	Chief Technology Officer	Reem Al-Otaibi	Pending
Prepared by	GRC Lead	Naif Alsalem	Complete
Endorsed by	Cybersecurity Steering Committee	—	Pending
Approver	Chief Executive Officer	Faisal Al-Harbi	Pending

Version history

Version	Date	Author	Change
0.1	7 Nov 2026	Naif Alsalem	First draft for review, translated from the Arabic lead text
0.2	9 Nov 2026	Naif Alsalem	Top risk level renamed "Catastrophic" (was "Critical")

Review cycle: At least annually, after every real activation of the plan or high-severity incident, and when a service or client is added or the cloud provider changes.

1. Introduction

This plan keeps the services Qayrawan Information Systems provides to its government clients running, and restores them within target times when an incident or disaster occurs, whether caused by a cyberattack, a technical failure, or the loss of a site or people. It treats risk R-17 and supports the treatment of risks R-07 and R-10 in the risk register.

2. Objectives

- Keep critical client services running, above all Client A's citizen portal.
- Restore systems within the recovery time objective (RTO) and recovery point objective (RPO) set in section 4.
- Protect client data and its integrity during disruption and recovery.
- Meet contractual service levels and the resilience requirements of the Essential Cybersecurity Controls (subdomain 3-1).
- Build readiness through regular testing and training.

3. Scope

The plan covers hosted client services, managed services, the corporate IT services they depend on, the Riyadh headquarters and the Jeddah office, key staff, and the suppliers the services rely on. It does not cover the continuity of client systems that QIS does not manage.

4. Business impact analysis

Recovery objectives were set for each service according to the client tier and the impact of an outage. These values are proposals until they are matched against the service levels in client contracts.

Service	Client	Impact of an outage	Max tolerable outage	RTO	RPO	Priority
Citizen portal	A	Citizen services stop, a breach of a critical contract under renewal, and reputational damage	8 hours	4 hours	15 minutes	1
Identity and email (Active Directory and Microsoft 365)	QIS	Staff lose access to all systems, and client communication stops	8 hours	4 hours	1 hour	1
Managed services and remote support	A, B, C, E	Clients cannot get support, and their staff's work is disrupted	8 hours	4 hours	N/A	2
Student services system	C	Student services stop during registration periods	24 hours	8 hours	1 hour	2
Licensing system	D	Licence applications are delayed	48 hours	24 hours	4 hours	3
Code repositories and build pipeline	A, F	Updates and security fixes cannot be released	72 hours	24 hours	24 hours	3
Finance and HR system	QIS	Payroll and payments are delayed	5 days	72 hours	24 hours	4

5. Scenarios and continuity strategies

Scenario	Services affected	Continuity strategy
Ransomware attack	Potentially all services	Isolate environments under the Incident Response Plan, and restore from immutable off-site backups
Cloud provider region outage	Hosted services	Run from a secondary in-Kingdom region with the same provider, with data replication
Loss of headquarters or the server room	Identity, managed services, finance	Work remotely and from the Jeddah office, rely on cloud-based Microsoft 365, and restore internal servers from off-site backups
Remote management tool or its vendor fails	Managed services	A backup tool pre-approved by clients, and phone and on-site support for critical cases

Scenario	Services affected	Continuity strategy
Key staff unavailable	All services	A documented deputy for every critical role, written runbooks, and securely stored emergency accounts

6. Continuity matrices for priority services

6.1 Citizen portal (Client A)

Description	A web portal delivering Client A's services to citizens, built and hosted by QIS.
Dependencies	The cloud provider's platform, the database, the national single sign-on service, the web application firewall, and the build pipeline.
Scenarios	A cloud region outage, a denial-of-service attack, ransomware, or a vulnerability that requires taking the portal offline.
Risk level	High (R-05, R-07, R-17).
Proactive measures	Database replication to a secondary region every 15 minutes, daily immutable backups, a DDoS protection service, documented failover steps, and an annual test.
During the incident: continuity	Show a maintenance page in coordination with Client A, and fail traffic over to the secondary region once data integrity is confirmed.
During the incident: recovery	Restore in order: database, application server, APIs, then the front end, checking data integrity before reopening the service.
After the incident	Confirm data completeness with the client, fail back to the primary region at a low-traffic time, and record lessons learned.

6.2 Identity and email

Description	Internal Active Directory synchronized with Microsoft Entra ID, and Microsoft 365 email.
Dependencies	Active Directory servers in the server room, internet connectivity, and Microsoft cloud services.
Scenarios	Server room failure, a compromised admin account, or ransomware on internal servers.
Risk level	High (R-02, R-07, R-10).
Proactive measures	Two securely stored cloud emergency accounts, off-site Active Directory backups, and a plan to reduce reliance on internal servers.
During the incident: continuity	Email and files continue directly through Microsoft 365, with temporary cloud accounts for key staff.
During the incident: recovery	Restore Active Directory from a clean backup into a clean environment, and reset passwords for admin and service accounts.

After the incident	Review all privileged accounts and update the restore procedures.

6.3 Managed services and remote support

Description	Technical support, device management and network monitoring for staff of Clients A, B, C and E.
Dependencies	The remote management tool, client VPNs, the support ticketing system, identity, and technicians.
Scenarios	The remote management tool fails, is shut down deliberately during an incident, or the office cannot be reached.
Risk level	Catastrophic before treatment (R-01, R-07).
Proactive measures	A backup tool pre-approved by each client, an emergency contact list for each client, and secure remote working for technicians.
During the incident: continuity	Phone support, technicians sent to client sites for critical cases, with Client A given priority.
During the incident: recovery	Restart the tool once the response team confirms it is clean, then restore access client by client after each one approves.
After the incident	Review permissions granted during the emergency and revoke the temporary ones.

7. Plan activation and roles

Role	Held by	Responsibility
Continuity lead	Chief Technology Officer	Decides to activate the plan and leads service restoration.
Crisis management team	CEO, CTO and CFO	Business and resource decisions; approves external communication.
Client coordinator	Head of Service Delivery	Informs clients and agrees priorities with them.
Incident response lead	GRC Lead	Coordinates the security track if the cause is a cyber incident.
Recovery teams	Hosting, IT operations and development	Carry out restore procedures according to the matrices.

Activation criteria: the continuity lead activates the plan when an outage of any priority 1 or 2 service is expected to exceed half its RTO, when the headquarters is lost, or at the request of the incident response lead.

Communication: communication with clients and regulators follows the communication plan in the Incident Response Plan (QIS-IRP-001, section 9).

8. Testing and maintenance

Activity	Frequency	Details
Citizen portal failover test	Annually	A real failover to the secondary region outside peak hours, measuring actual recovery time against the target.
Backup restore test	Quarterly	Restore a sample of systems, including Active Directory.
Simulation exercise	Annually	A loss-of-headquarters or ransomware scenario, run jointly with the Incident Response Plan.
Plan review	Annually	And whenever services, clients or the cloud provider change; contact lists updated quarterly.

Items to confirm: match the recovery objectives in section 4 to the service levels in each contract, confirm the cloud provider offers a secondary in-Kingdom region, and get each client's approval for the backup remote management tool.